Maker Day # 2

GCP Compliance Automation

AI-Powered Three-Step Solution

LLM + RAG | NIST Controls | Rego Automation | GCP Services

TEAM

AN Anusha × | AL Alissa × | AN Anshul × | SA Sanjana × | SA Sarah × | YA Yash × | + Add

The Problem

Enterprises cannot systematically map, implement, and continuously verify compliance controls on GCP — making onboarding manual, fragmented, and slow.

CURRENT PROCESS

01 Starting Point
Org decides to integrate with GCP

02 Onboarding & Channel
Self-service, professional services, or white glove

03 Foundational Services
Configure 25-30 core GCP services

04 Audit the Flow
3-line defense: execute, monitor, gather

↑ Where it breaks

05 Create Mapping Spreadsheet
Manually map NIST controls to GCP services in a spreadsheet

06 Check Logs & Screenshots
Check logs via Screenwalk and capture screenshots as audit evidence

PROBLEMS

Mapping Gap

Root Cause: No standardized framework exists to map regulatory controls to GCP services.
Impact: 60% of GCP services have no compliance definition and are handled manually.

~40%
GCP mapped

Automated Evidence Gap

Root Cause: No mechanism exists to automatically collect audit evidence from GCP.
Impact: Teams screenshot consoles into spreadsheets, which is unreliable and not reusable.

0%
Automated

Monitoring Gap

Root Cause: Controls are validated only at audit time and never on a continuous basis.
Impact: Configuration drift goes undetected for months, creating compounding compliance risk.

1×/yr
Audit cadence

Low Coverage of Rego, Policy-as-Code

Root Cause: Generating Rego policies per control-service pair at enterprise scale is not feasible.
Impact: Compliance controls are never enforced as code and exist only as static documents.

For Most
Enterprises

⭐ **North Star Metric: Time to Compliance (TTC) — Today: ~180 days, ⭐GCP's Market Share**

KPIs: Mapping Coverage (%) · Evidence Automation (%) · Mean Time to Detect Non-Compliance · Audit Prep Time ↓

GCP Compliance Automation

An AI-Powered Three-Step Solution

01

NOW

Control Mapping

NIST → GCP Services

RAG-powered agent maps every NIST control to relevant GCP services, replacing manual rule-writing with intelligent LLM reasoning.

02

NOW

Monitoring & Evidence

Automated Audit Flow

Agent defines, executes and stores test cases per control - collecting audit evidence on pass and triggering alerts on failure.

03

FUTURE

Rego Automation

Policy-as-Code Generation

Auto-generate OPA/Rego policies from mapped controls for continuous, enforcement-as-code across all GCP resources.

Powered by LLMs + RAG · Reduces manual effort · Continuous compliance

STEP

01

Control Mapping

Map every NIST control to the exact GCP services responsible for enforcement — using LLM reasoning over a rich knowledge base.

Output

Control-to-Service Mapping Agent

How It Works

GCP Service Manuals

Service capabilities & use cases

Framework Controls (eg NIST)

All controls & their exact intent

Existing Audit Docs & OSCAL

Historical implementation data (KB)

Mapping

Agent

LLM

Reasoning Engine

MAP OUT

Why not rule-based?

Too many permutations for humans to define. LLM dynamically evaluates context and intent for each control-service pair.

Example: Control 1 (Restrict access to authorized users) → Cloud IAM, Cloud Identity, VPC Service Controls, Identity-Aware Proxy

Mapping generated and validated by Agent — not hand-coded

STEP

02

Monitoring & Evidence

Automate test case creation, execution and evidence collection for every mapped control — with real-time alerting on failures.

Output

Test Definition + Automation + Evidence Agent

Automated Pipeline

Inputs

Existing test cases (KB)

AI-generated additions

Define Tests

Per-control test suite

AI-enhanced coverage

Run Tests

Automated execution

Pass / Fail evaluation

Outcomes

PASS → store evidence

FAIL → trigger alert

Test Cases

Comprehensive coverage per control

Automation

Zero-touch test execution

Evidence

Audit-ready artifact storage

Alerts

Instant failure notification

STEP

03

Rego Automation

FUTURE SCOPE

Auto-generate OPA/Rego code directly from mapped controls — enabling continuous, enforcement-as-code across all GCP resources without any manual rule authoring.

Output

Rego Policy Generator Agent

How It Works

Control-Service Mapping

Output from Step 1 agent

NIST Control Intent

Semantic meaning of each control

REGO Resource Schema

Service configs & policy structures

Agent

LLM + RAG

Policy Synthesis

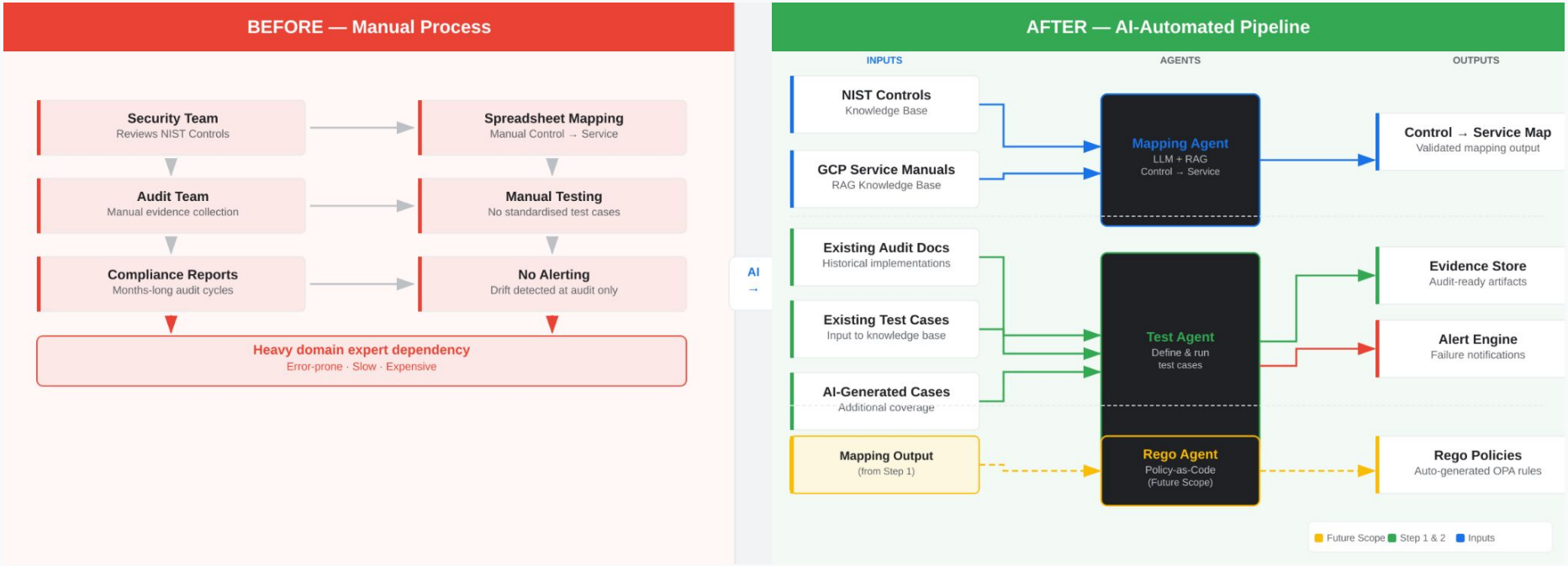
REGO OUT

What this unlocks:

- Continuous enforcement — policies applied automatically, not just at audit time
- Zero manual Rego authoring — LLM generates policy code from control semantics
- Full compliance-as-code — version-controlled, reviewable, testable policies

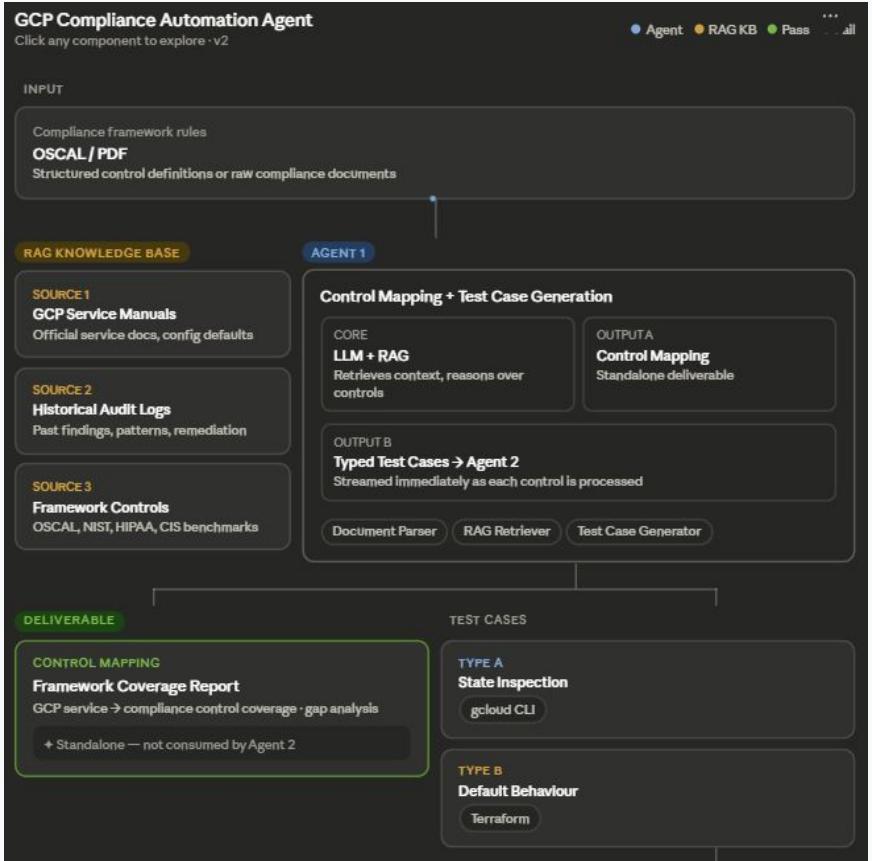
Before vs After

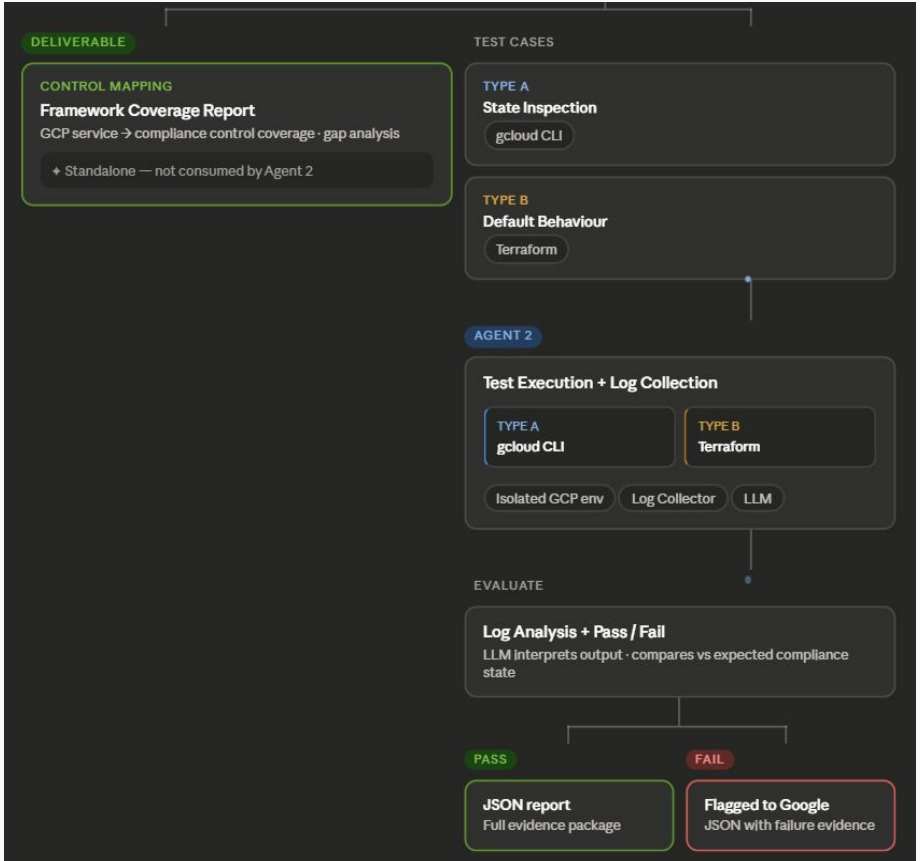
Manual Compliance Process → AI-Automated Pipeline



Solution Architecture

Live Demo - https://claude.ai/public/artifacts/a93e556a-6719-44be-b269-a19658463d47





Competitive Advantage

Where we stand today -- and where LLM-powered automation takes us ahead of the field

Parity with Market Leaders

Catching Up -- Future-Proofed

Steps 1 & 2 achieve feature parity with AWS Security Hub and Prisma Cloud through automated control mapping and evidence collection.

Our LLM-powered approach future-proofs the solution -- new frameworks and controls are mapped automatically. Custom frameworks, a manual process in AWS and Prisma Cloud, are handled automatically here.

Faster Onboarding equals Market Capture

From months to minutes

Reduces Time to Compliance from ~180 days to near real-time through automated mapping and evidence collection.

Accelerates enterprise onboarding, positioning Google Cloud to win customers where speed and scalability are critical.

Agentic Compliance Leadership

Adaptive compliance powered by AI

LLM-powered mapping replaces static, rule-based systems — enabling automatic adaptation to new frameworks and custom controls.

Positions Google Cloud as a leader in intelligent, scalable compliance — using an LLM feature not yet productized by AWS or Prisma Cloud today.

LLM-powered · Future-proof framework mapping · First-to-market built-in Rego automation tool · Continuous enforcement-as-code

Infrastructure and Platform Requirements

6 Key Infrastructure Requirements for Multi-Agent AI Deployment

01

Knowledge Base

GCP Docs, Audit Logs, Frameworks

02

Ecosystem & Execution

Secure Compute, Orchestration

03

Internal API Integrations

Control Mapping, Validation

04

Reasoning Model API

Keys, Budgets, Token Capacity

05

Vector Database

RAG, Semantic Search, Scale

06

Dev Tooling

IDE, Debug, CI/CD

Sources - Correspondance with Aaron

Hi Aaron,

I hope you're doing well.

We've put together a process flow diagram to capture our current understanding of the Google Cloud compliance audit lifecycle for regulated customers. I've attached the draft to this email, and we would value your expertise to help us enrich it and ensure it reflects the ground reality accurately.

Specifically, we wanted to check if our understanding of the process is correct or if there are any gaps we should address. If anything looks off, please feel free to correct us.

A few specific areas where we are looking for clarification:

- **Auditor Use of OSCAL:** We are curious if auditors actually utilize the **OSCAL** files generated at the L1 (Execution) level. In your experience, do they leverage these files, or do they default to manual spreadsheets and then try to map evidence back to the **NIST** frameworks themselves?
- **Referencing OSCAL:** If they do use OSCAL, at what specific point in the flow do they typically refer to it in the process we described?
- **Audit Scope:** Is there anything else the auditor does that we didn't capture in the flow?

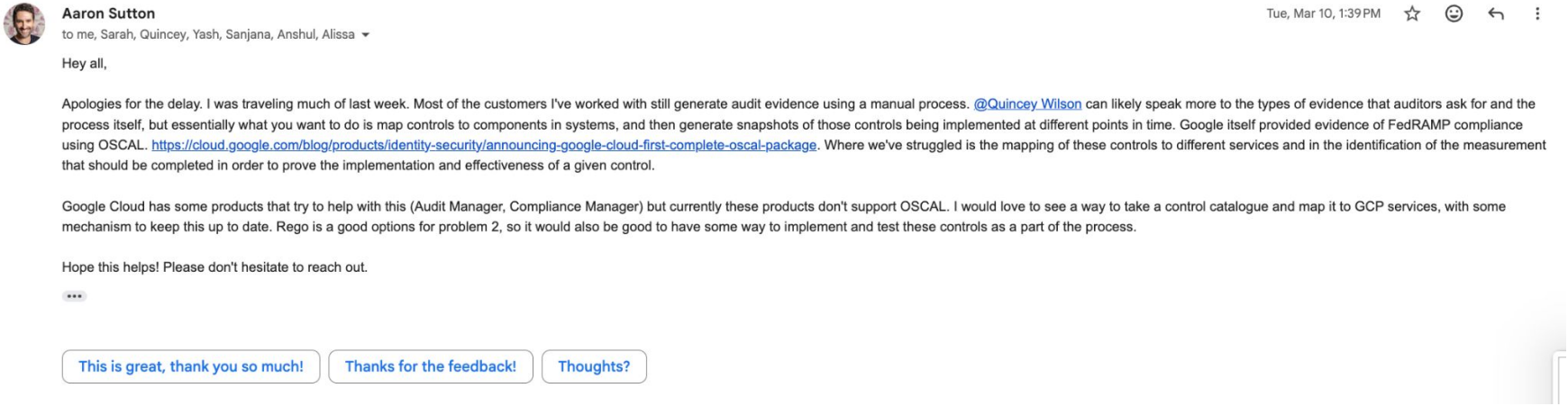
Proposed Solutions Regarding the bottlenecks we identified, here are the solutions we discussed last time in our call:

- **Problem 1 (Mapping Coverage):** To address the mapping gap (where only ~40% of products/services are currently covered), we talked about exploring using **Neo4j** to create a graph-based map that can automate and scale the control-to-product mapping process.
- **Problem 2 (Manual Evidence Toil):** To solve the manual part of evidence collection, we are proposing a system that runs **Rego** code more frequently to capture automated snapshots. This would create a better audit trail that maps directly against **OSCAL** and subsequently to **NIST**, moving us toward continuous monitoring.

We look forward to hearing your thoughts on these approaches.

Regards,
Anusha

Sources - Correspondance with Aaron



Aaron Sutton
to me, Sarah, Quincey, Yash, Sanjana, Anshul, Alissa

Tue, Mar 10, 1:39 PM

Hey all,

Apologies for the delay. I was traveling much of last week. Most of the customers I've worked with still generate audit evidence using a manual process. @Quincey Wilson can likely speak more to the types of evidence that auditors ask for and the process itself, but essentially what you want to do is map controls to components in systems, and then generate snapshots of those controls being implemented at different points in time. Google itself provided evidence of FedRAMP compliance using OSCAL. https://cloud.google.com/blog/products/identity-security/announcing-google-cloud-first-complete-oscal-package. Where we've struggled is the mapping of these controls to different services and in the identification of the measurement that should be completed in order to prove the implementation and effectiveness of a given control.

Google Cloud has some products that try to help with this (Audit Manager, Compliance Manager) but currently these products don't support OSCAL. I would love to see a way to take a control catalogue and map it to GCP services, with some mechanism to keep this up to date. Rego is a good options for problem 2, so it would also be good to have some way to implement and test these controls as a part of the process.

Hope this helps! Please don't hesitate to reach out.

This is great, thank you so much! | Thanks for the feedback! | Thoughts?

Thank You!